

บทที่ 5

การพัฒนาโปรแกรมไฟร์วอลล์

5.1 แนวคิด

โปรแกรมไฟร์วอลล์เป็นโปรแกรมเพอร์ซันนอลไฟร์วอลล์ ที่มีระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์ที่พัฒนาขึ้นเองโดยภาษา C++ เพื่อใช้งานร่วมกับไฟร์สแตนด์ในการรับกฎของเพอร์ซันนอลไฟร์วอลล์สำหรับแต่ละเครื่องลูกข่าย โดยเป็นการใช้งานไฟร์วอลล์แบบอิงผู้ใช้คือเมื่อผู้ใช้งานมีการล็อกอินใช้งานเครื่องที่อยู่ในระบบเครือข่ายภายในเครื่องใดก็ตาม ก็จะมีกฎสำหรับผู้ใช้คนนั้นในการใช้งานเพอร์ซันนอลไฟร์วอลล์เสมอ

5.2 ขอบเขตและความสามารถ

ในระบบจะมีเครื่องลูกข่ายหลายเครื่องโดยทุกเครื่องจะมีการติดตั้ง เพอร์ซันนอลไฟร์วอลล์ ซึ่งก็คือเอเจนต์ที่ฝังตัวทำงานอยู่แบบอัตโนมัติ โดยจะมีการควบคุมดูแลจากส่วนกลางโดยผู้ใช้งานไม่รับรู้ถึงการทำงานของเอเจนต์ รวมไปถึงผู้ดูแลระบบสามารถกำหนดกฎการป้องกันการบุกรุกให้ผู้ใช้ในแต่ละกลุ่มตามความเหมาะสม

อีกทั้งยังมีส่วนของการทำงานที่เป็นระบบตรวจจับผู้บุกรุกที่คอยทำหน้าที่ตรวจสอบว่ามีการบุกรุกเข้ามาที่เครื่องลูกข่ายนั้นๆหรือไม่ ถ้าจะมีการแจ้งเตือนไปยังเครื่องเซิร์ฟเวอร์กลางเพื่อนำผลที่ได้ไปวิเคราะห์หาแนวทางป้องกันต่อไป และส่วนตรวจการเชื่อมต่อเครือข่ายของโปรเซสต่างๆเพื่อให้ผู้ใช้งานได้รับรู้ว่ามีการเชื่อมต่อเครือข่ายอยู่บ้าง และสามารถกำจัดโปรเซสที่น่าสงสัยได้ด้วยตนเอง ทำให้ผู้ใช้สามารถป้องกันตนเองได้ในระดับหนึ่ง

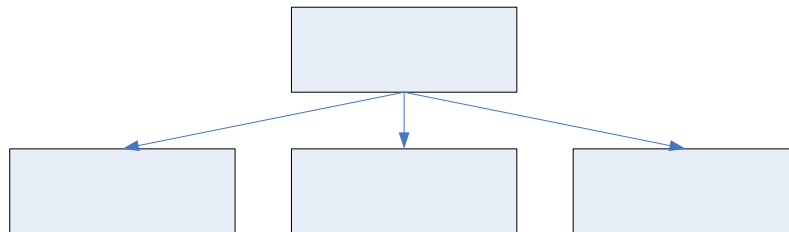
5.3 การพัฒนาโปรแกรม

การพัฒนาโปรแกรมไฟร์วอลล์จะใช้ Firewall-Hook Driver ซึ่งเป็น DDK (Driver Development Kit) ของทางบริษัทไมโครซอฟต์ ซึ่งไดรเวอร์ตัวนี้ใช้ในการฟิลเตอร์แพ็คเก็ต การเขียนโปรแกรมนั้นจะใช้เฮดเดอร์(Header) ที่ชื่อว่า IpDrvFw.h โดยภายในเฮดเดอร์(Header) นี้จะมีโครงสร้างต่างๆที่ใช้ในการฟิลเตอร์ และใช้ WinPCap ช่วยในการดักจับแพ็คเก็ตเพื่อมาวิเคราะห์หาว่ามีการบุกรุกระบบเกิดขึ้นหรือไม่ โดยกฎที่ใช้ในการฟิลเตอร์นั้นจะรับมาจากฐานข้อมูลของแอ็กทีฟไดเรกทอรี (Active Directory Database)

5.4 การทำงานของโปรแกรม

ไฟร์วอลล์เป็นเพอร์ซันนอลไฟร์วอลล์ซึ่งจะแบ่งการทำงานออกเป็น 3 ส่วน คือ

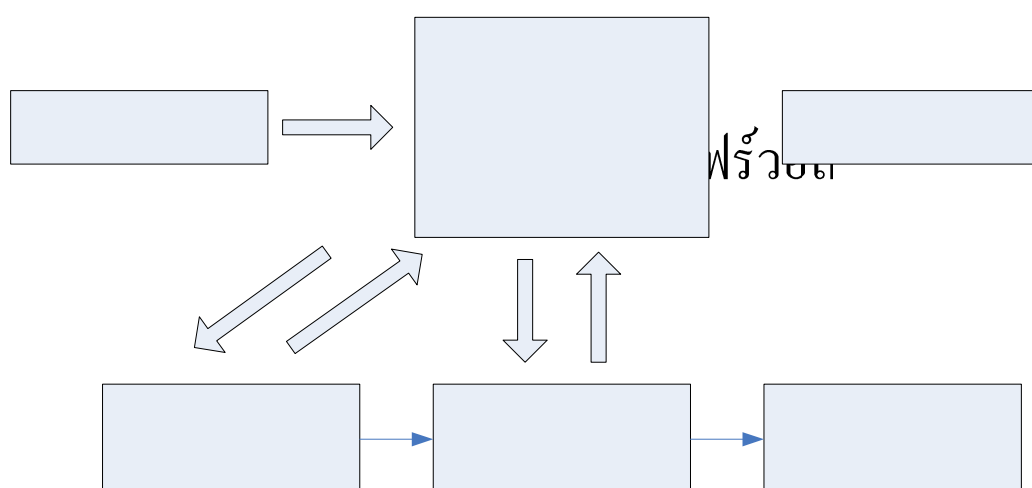
1. ไฟร์วอลล์
2. ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์
3. ระบบตรวจการใช้งานเครือข่ายของโปรเซส



รูปที่ 5.1 แสดงส่วนประกอบเพอร์ซันนอลไฟร์วอลล์

5.3.1 แพ็กเก็ตฟิลเตอร์ริงไฟร์วอลล์บนวินโดวส์ XP

เพอร์ซันนอลไฟร์วอลล์ที่พัฒนามีลักษณะการทำงานแบบแพ็กเก็ตฟิลเตอร์ริง(Packet Filtering) โดยจะมีการตรวจสอบแพ็กเก็ตด้วยฟังก์ชันฟิลเตอร์ว่าจะอนุญาตหรือไม่อนุญาตให้แพ็กเก็ตนั้นผ่านไปได้ โดยที่ฟังก์ชันฟิลเตอร์จะมีการกำหนดลำดับไว้แล้วให้ระบบเรียกฟังก์ชันฟิลเตอร์เข้าไปทำงานทีละฟังก์ชันตามลำดับ จนกว่าจะมีฟังก์ชันใดฟังก์ชันหนึ่งส่งค่ากลับเป็น “DROP PACKET” ถ้าฟังก์ชันทั้งหมดส่งค่ากลับเป็น “ALLOW PACKET” แพ็กเก็ตเหล่านั้นจะสามารถผ่านไปได้



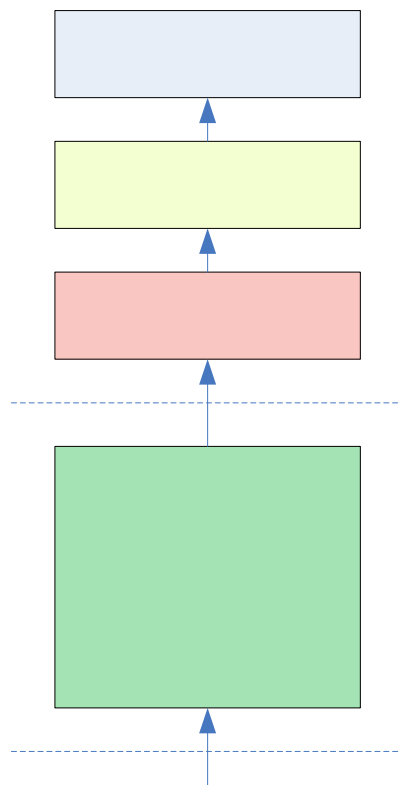
รูปที่ 5.2 แสดงขั้นตอนการทำงานของไฟร์วอลล์

ขั้นตอนการทำงานของไฟร์วอลล์ตามรูปที่ 5.2

- 1) เมื่อเครื่องได้รับแพ็คเกจเข้ามา โดยที่ IP Driver มีฟังก์ชันฟิลเตอร์อยู่ตามที่กำหนดไว้
- 2) IP Driver จะส่งแพ็คเกจนั้นเข้าไปโดย ผ่านเข้าไปยังฟังก์ชันฟิลเตอร์ตามลำดับไปเรื่อยๆ โดยรอค่าที่ส่งกลับออกมา
- 3) สมมุติฟังก์ชันแรกส่งค่ากลับเป็น “ALLOW PACKET” เมื่อ IP DRIVER ได้รับค่าส่งกลับจากฟังก์ชันแรกเป็น “ALLOW PACKET”
- 4) ดังนั้น IP DRIVER จะส่งแพ็คเกจนั้นไปที่ฟังก์ชันที่สองต่อไปในกรณีนี้
- 5) สมมุติให้ฟังก์ชันที่สองนี้ส่งค่ากลับเป็น “DROP PACKET” เมื่อ IP DRIVER ได้รับค่าส่งกลับจากฟังก์ชันที่สองเป็น “DROP PACKET” ดังนั้น IP DRIVER จะไม่ส่งแพ็คเกจนี้ต่อไปยังระบบ และจะไม่ส่งไปยังฟังก์ชันต่อไปอีก

5.3.2 ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์

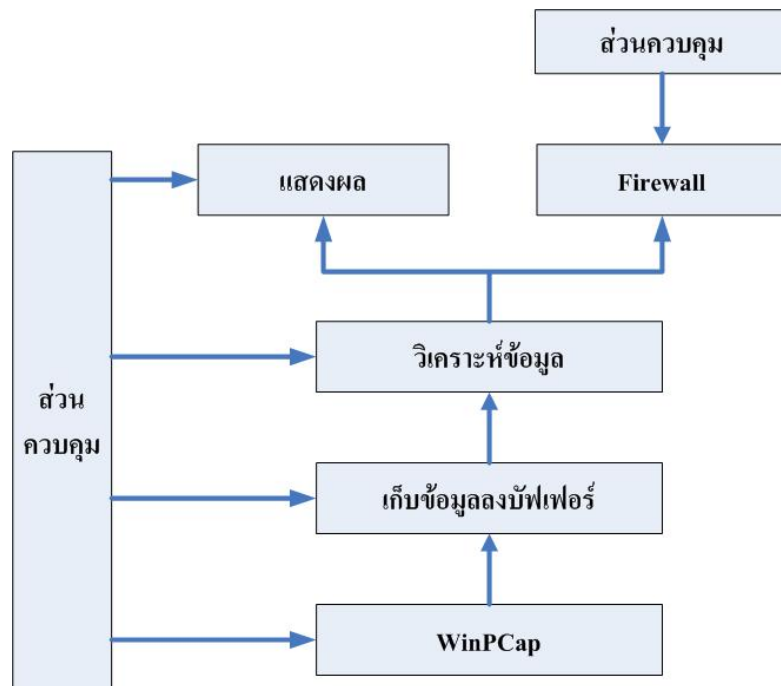
ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์จะอาศัยคุณสมบัติ และ ความสามารถของ WinPCap ซึ่งเป็นไลบรารีที่ทำการติดต่อกับการ์ดแลน เพื่อทำการควบคุมการทำงานของ การ์ดแลน และตรวจจับแพ็คเกจ เพื่อนำมาวิเคราะห์ผลว่ามีการ โจมตีเกิดขึ้นหรือไม่



รูปที่ 5.3 แสดงระดับชั้นการทำงานของ WinPCap

การทำงานของระบบตรวจจับผู้บุกรุกนั้นจะแบ่งการทำงานออกเป็น 2 ส่วนหลักๆด้วยกัน คือ ส่วนการตรวจจับแพ็คเก็ตเก็บลงบัฟเฟอร์ และส่วนวิเคราะห์ผลแพ็คเก็ตที่ได้ดักจับมา เมื่อวิเคราะห์ผลเสร็จก็จะแสดงผล พร้อมกับส่งแพ็คเก็ตไปฟีดเตอร์ตามกฎที่กำหนดเอาไว้ดังรูปที่ 5.3

โดยการทำงานทั้ง 2 ส่วนนี้จะมีการแบ่งเชรด (Thread) การทำงานเพื่อที่จะสามารถดักจับแพ็คเก็ตและวิเคราะห์ผลไปได้พร้อมๆกัน



รูปที่ 5.4 โครงสร้างของระบบตรวจจับผู้บุกรุกทำงานร่วมกับไฟร์วอลล์

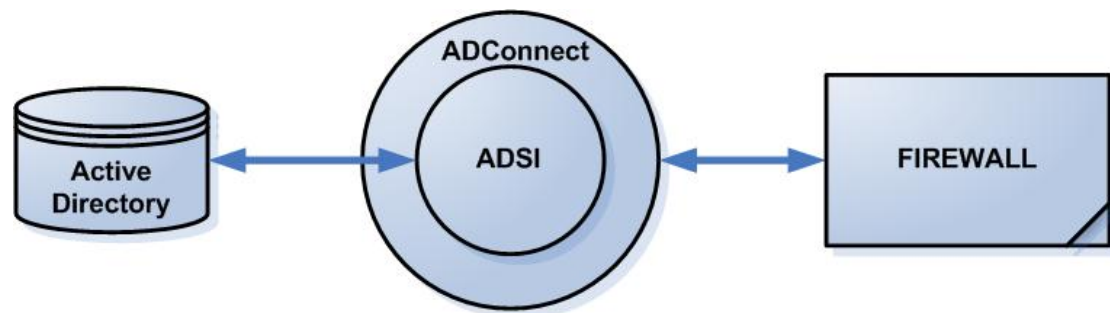
5.3.2 ระบบตรวจการใช้งานเครือข่ายของโปรเซส

ระบบตรวจการใช้งานเครือข่ายของโปรเซสจะทำงานคล้ายกับคำสั่ง `netstat -bn` โดยจะแสดง โปรเซสต่างๆที่กำลังใช้งานเครือข่ายอยู่ในขณะนั้น พร้อมทั้งบอกโปรเซสไอดี(PID) โปรโตคอล(Protocol) โลคอลแอดเดรส (Local Address) รีโมตแอดเดรส(Remote Address) และสถานะของการเชื่อมต่อ (State) โดยที่จะมีเวลาการอัปเดตข้อมูลตามเวลาที่ผู้ใช้ได้ตั้งเอาไว้

ระบบตรวจการใช้งานเครือข่ายของโปรเซสนี้มีความสามารถที่จะจบการทำงานของโปรเซส (Kill Connection) และ ปิดการเชื่อมต่อเครือข่ายของโปรเซสนั้นได้ (Close Connection) ถ้าหากพบว่ามีโปรเซสใดที่มีการใช้งานเครือข่ายที่น่าสงสัย ผู้ใช้ก็สามารถจบการทำงานของโปรเซสหรือปิดการเชื่อมต่อได้ทันที เพื่อให้ผู้ใช้สามารถป้องกันตนเองได้อีกทางหนึ่ง

เนื่องจากเพอร์ซันนอลไฟร์วอลล์ (Personal Firewall) จะมีความสามารถในการที่จะรับกฎเพื่อเริ่มการทำงานของไฟร์วอลล์จากเครื่องโดเมนคอนโทรลเลอร์ที่ได้ติดตั้งแอคทีฟไดเรกทอรีไว้และจะมีการส่งล็อกไฟร์ไปเก็บไว้ยังแอคทีฟไดเรกทอรีเมื่อมีการตรวจพบการโจมตี หรือ มีสิ่งผิดปกติ

เกิดขึ้น ซึ่งโครงสร้างการทำงานของส่วนที่ใช้ในการติดต่อกับเครื่องเซิร์ฟเวอร์ แสดงดังรูปที่ 6-6 โดยเพอร์ซันนอลไฟร์วอลล์จะมีการติดต่อ ไปยังเซิร์ฟเวอร์โดยผ่านคลาส ADConnect ที่สร้างขึ้น



รูปที่ 5.5 แสดงโครงสร้างส่วนติดต่อกับเซิร์ฟเวอร์

เพอร์ซันนอลไฟร์วอลล์จะติดตั้งอยู่ที่เครื่องลูกข่ายทุกเครื่องในระบบ โดยมีหน้าที่การทำงานดังนี้

- เป็นไฟร์วอลล์ชนิดแพ็คเกจฟิลเตอร์ริง (Packet Filtering Firewall)
- ตรวจสอบผู้บุกรุกทางเครือข่ายที่เข้ามาที่เครื่องลูกข่าย รวมทั้งสิ่งผิดปกติที่ไม่เป็นไปตามมาตรฐานของ โพรโทคอลทีซีพี (TCP) , ยูดีพี(UDP), ไอพี(IP), ไอซีเอ็มพี(ICMP)
- ตรวจสอบการเชื่อมต่อเครือข่ายของโปรเซสต่างๆ โดยผู้ใช้สามารถจบการทำงานของโปรเซสและปิดการเชื่อมต่อเครือข่ายของโปรเซสใดๆได้
- ส่งการแจ้งเตือนกลับไปยังล็อกมอนิเตอร์เมื่อตรวจจับได้ว่าการบุกรุกเกิดขึ้น